

Labo maison : Active Directory & Sécurité

Rapport de projet, Phase 1 (IAM / Active Directory)
Antikat Olouchessi, Polytechnique Montréal, certificat en cybersécurité

1. Contexte et objectif

Pour ce projet personnel, j'ai construit un petit environnement d'entreprise dans Microsoft Azure : un contrôleur de domaine Active Directory et un poste client Windows 11 joint à ce domaine. Le but était simple : avoir des preuves concrètes de mes compétences en IAM, pas juste des connaissances théoriques. J'y ai travaillé la création d'un domaine, la structuration des identités (unités d'organisation, utilisateurs, groupes), le principe du moindre privilège (RBAC), les stratégies de groupe (GPO), et des tests d'accès réseau.

J'ai monté l'environnement dans Azure plutôt qu'en local avec VirtualBox ou UTM, parce que mon Mac (puce Apple Silicon, ARM64) n'est pas compatible avec Windows Server en x64. Ça m'a aussi permis d'apprendre le portail Azure au passage : création de machines virtuelles, gestion des quotas, réseaux virtuels et groupes de sécurité réseau (NSG), un bon plus pour un profil cybersécurité orienté cloud.

2. Architecture du labo

Machine	Rôle	Détails
DC01	Contrôleur de domaine	Windows Server 2022 Datacenter, domaine labo.local, rôles AD DS + DNS
Client01	Poste de travail	Windows 11 Pro, joint au domaine labo.local
Réseau	vnet-eastus-1	Réseau virtuel Azure commun aux deux VM, NSG configuré

3. Cycle de vie d'un compte utilisateur

Voici le cycle de vie complet d'un compte, de sa création jusqu'à la vérification de ses accès. C'est un des livrables attendus du projet.

1. Création	Je crée l'utilisateur dans l'unité d'organisation de son département (TI, Ventes ou RH), via Active Directory Users and Computers.
2. Attribution de rôle	J'ajoute l'utilisateur au groupe de sécurité de son département (Gr-TI, Gr-Sales, Gr-RH), qui porte les permissions liées à son rôle.
3. Application des accès	Le groupe reçoit des permissions NTFS précises sur le dossier partagé de son département, avec héritage désactivé et accès large par défaut retiré. C'est le principe du moindre privilège.
4. Revue d'accès	Je teste en me connectant avec le compte sur le poste client et en essayant d'ouvrir les trois dossiers partagés : seul celui du bon groupe s'ouvre, les deux autres refusent l'accès.
5. Désactivation (à venir)	Prochaine étape : désactiver le compte dans Active Directory quand un employé quitte, ce qui retire automatiquement tous les accès liés à ses groupes.

4. Active Directory : structure et stratégies de groupe

4.1 Unités d'organisation, utilisateurs et groupes de sécurité

J'ai créé trois unités d'organisation (TI, Ventes, RH), chacune avec deux utilisateurs et un groupe de sécurité de département. L'idée : gérer les accès par rôle, pas un par un.

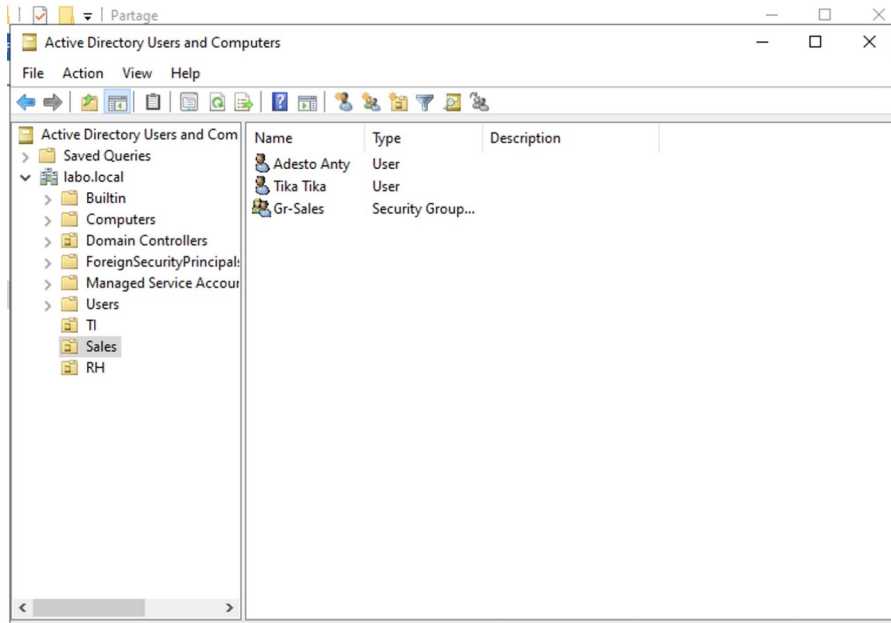


Figure 1. Structure des OU, utilisateurs et groupe de sécurité dans Active Directory Users and Computers (exemple : OU Sales).

On voit ici l'OU Sales avec ses deux utilisateurs (Adesto Anty et Tika Tika) et le groupe de sécurité Gr-Sales. J'ai reproduit exactement la même structure pour les OU TI et RH : deux comptes par département, plus un groupe qui centralise leurs permissions. Cette organisation me permet de gérer les accès par groupe plutôt qu'un par un, ce qui est beaucoup plus simple à maintenir si l'entreprise grandit.

4.2 Stratégies de groupe (GPO)

J'ai configuré trois GPO pour renforcer la sécurité du domaine :

- Blocage de tous les périphériques de stockage amovible, comme les clés USB (GPO-Restriction-USB).
- Verrouillage automatique de la session après 5 minutes d'inactivité (GPO-Verrouillage-Ecran).
- Complexité des mots de passe (Default Domain Policy), déjà activée par défaut sur Windows Server, mais que j'ai vérifiée et documentée.

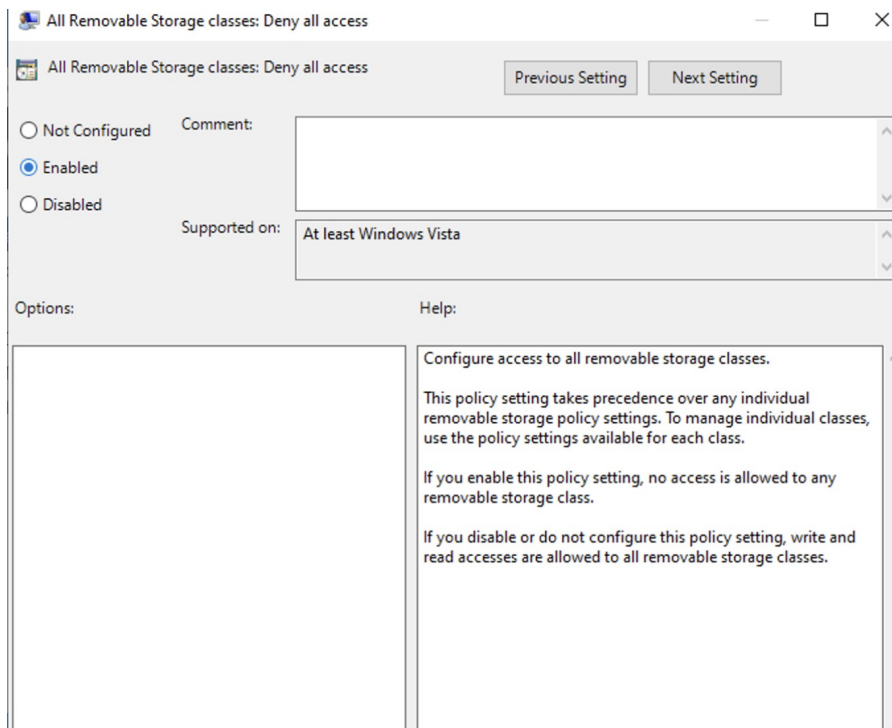


Figure 2. Restriction de l'accès aux périphériques de stockage amovible.

Cette GPO bloque l'utilisation des clés USB et autres supports amovibles sur les postes du domaine. C'est une mesure simple, mais efficace contre deux risques courants : le vol de données et l'introduction de logiciels malveillants par une clé infectée.

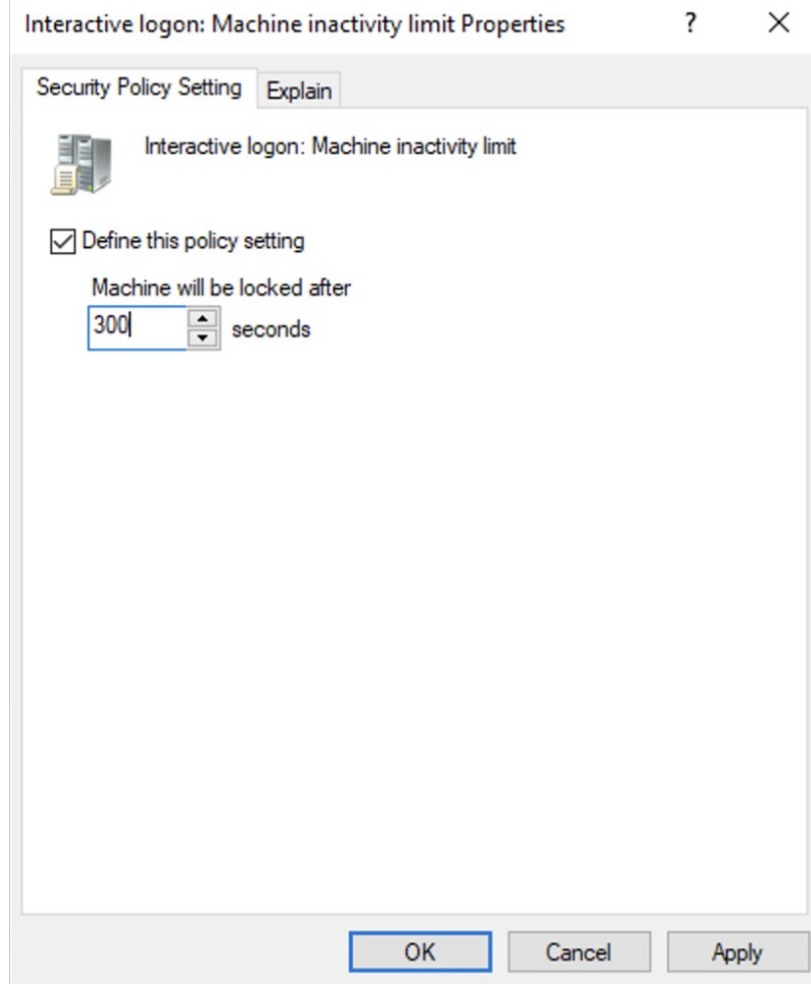


Figure 3. Verrouillage automatique de la session après 5 minutes d'inactivité.

J'ai configuré cette GPO pour que l'écran se verrouille tout seul si personne ne touche au clavier ou à la souris pendant 5 minutes. Ça évite qu'une session reste ouverte sans surveillance, par exemple si quelqu'un s'absente de son poste.

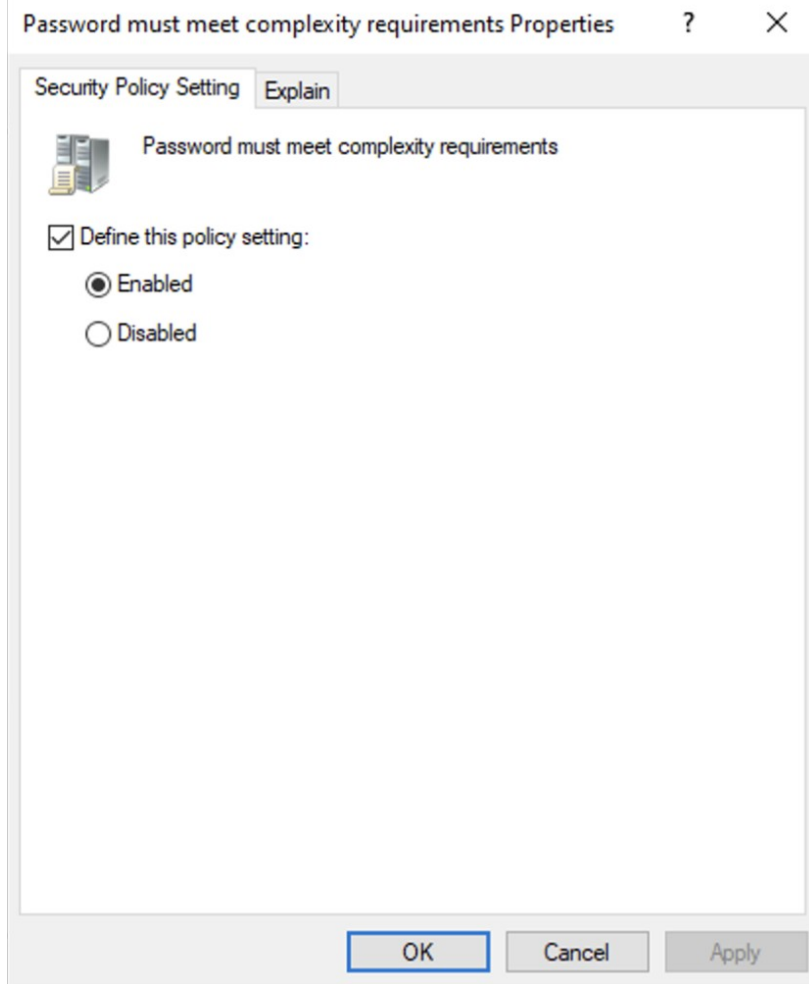


Figure 4. Politique de complexité des mots de passe, activée dans la Default Domain Policy.

Cette politique oblige les comptes du domaine à utiliser des mots de passe avec majuscules, minuscules, chiffres et caractères spéciaux. Elle est activée par défaut sur Windows Server, mais je voulais la vérifier moi-même pour m'assurer qu'elle fait bien partie de ma posture de sécurité.

4.3 Connexion du poste client avec un compte de domaine

Une fois Client01 joint au domaine labo.local, j'ai autorisé le groupe Gr-RH à ouvrir une session à distance sur cette machine (Remote Desktop Users), puis testé la connexion avec un compte de ce groupe. Ça a fonctionné.

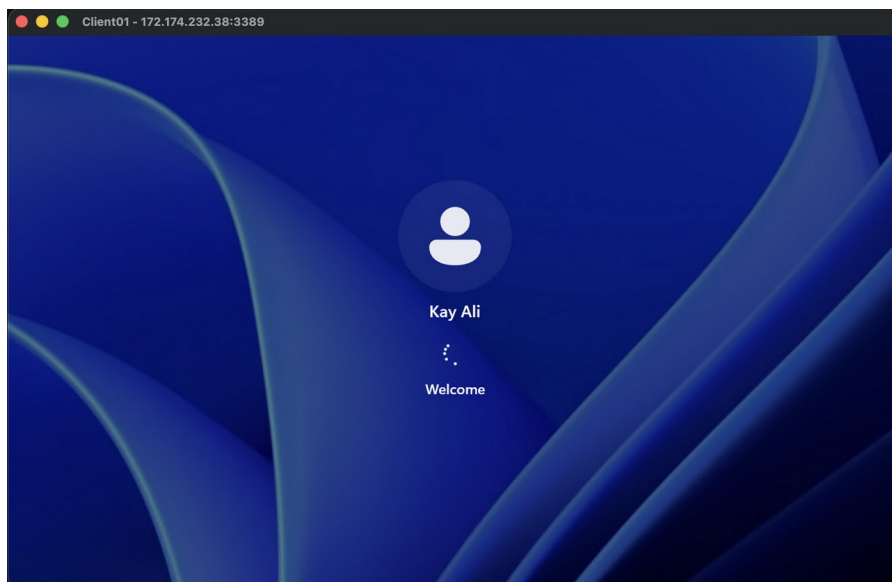


Figure 5. Connexion à Client01 avec un compte de domaine (Kay Ali, membre de Gr-RH).

Ce test confirme que Client01 reconnaît bien les comptes du domaine labo.local, et que le groupe Gr-RH a les droits nécessaires pour ouvrir une session à distance sur cette machine. Sans cette autorisation précise, la connexion aurait été refusée même avec les bons identifiants.

5. Principe du moindre privilège (RBAC) et test réseau

Pour tester le RBAC concrètement, j'ai créé un dossier partagé sur DC01 avec un sous-dossier par département (Rh, Sales, TI), puis restreint les permissions NTFS de chaque sous-dossier au bon groupe de sécurité, en retirant l'accès par défaut hérité.

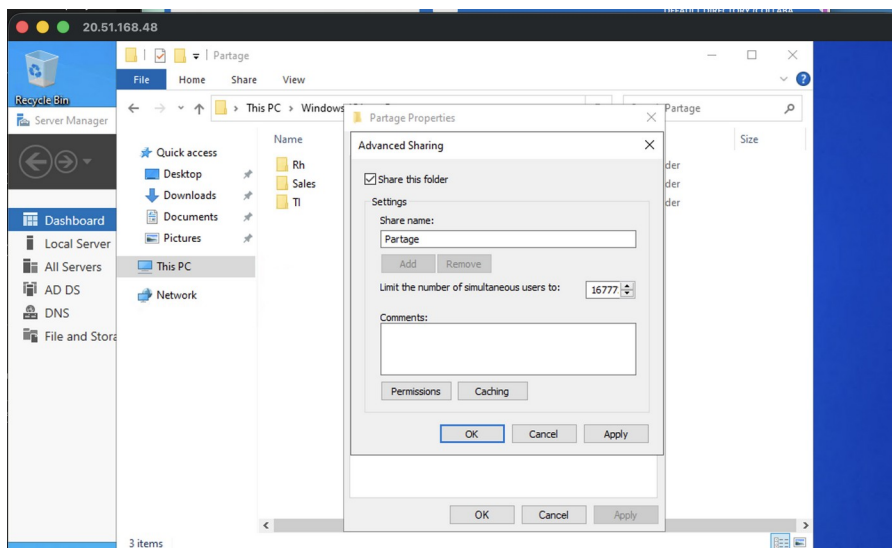


Figure 6. Partage réseau « Partage » activé sur DC01 (onglet Sharing).

J'ai activé le partage réseau sur ce dossier pour le rendre accessible depuis les autres machines du domaine. C'est la première étape avant de restreindre l'accès par département.

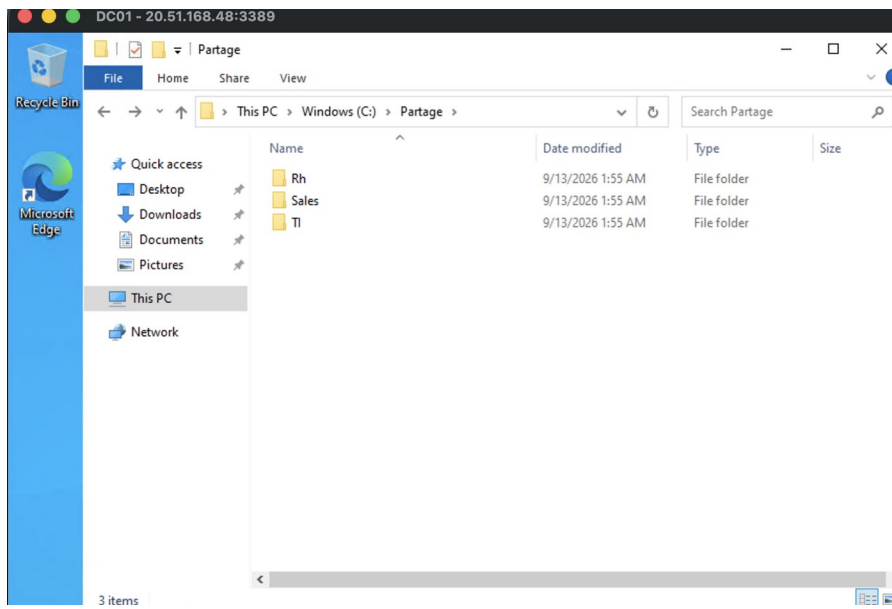


Figure 7. Contenu du dossier partagé, un sous-dossier par département.

Chaque sous-dossier correspond à un département (Rh, Sales, TI). C'est sur ces trois sous-dossiers que j'ai ensuite appliqué des permissions NTFS différentes selon le groupe de sécurité.

5.1 Tentative d'accès depuis Internet (Mac personnel)

J'ai d'abord essayé d'accéder au partage depuis mon Mac, à l'extérieur d'Azure, après avoir ajouté une règle de pare-feu (NSG) pour autoriser le trafic SMB (port 445) seulement depuis mon adresse IP publique. Ça n'a pas fonctionné : la plupart des fournisseurs Internet résidentiels bloquent le port 445 en sortie pour des raisons de sécurité, peu importe ce qu'on configure du côté Azure.

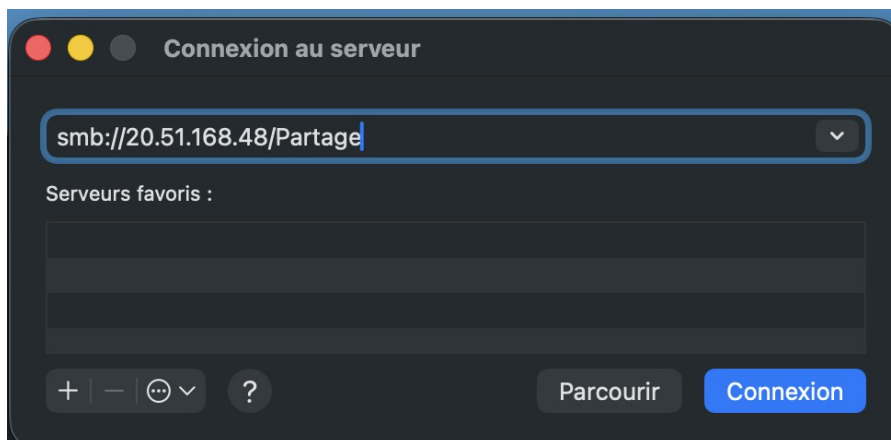


Figure 8. Tentative de connexion SMB depuis mon Mac personnel, bloquée par le fournisseur Internet.

Le blocage vient du fournisseur Internet, pas d'Azure : le port 445 sortant est fermé sur la majorité des connexions résidentielles pour éviter les abus (c'est un port historiquement ciblé par des vers informatiques). Ma règle NSG était pourtant bien configurée.

5.2 Accès depuis le réseau interne (Client01)

Depuis Client01, sur le même réseau qu'DC01, l'accès au partage (\\DC01\\Partage) fonctionne directement. Mon vrai test : ouvrir les trois sous-dossiers avec un compte du groupe Gr-RH. Le dossier Rh s'ouvre normalement, TI et Sales renvoie « Access is denied ». Les permissions par groupe font exactement ce qu'elles doivent faire.

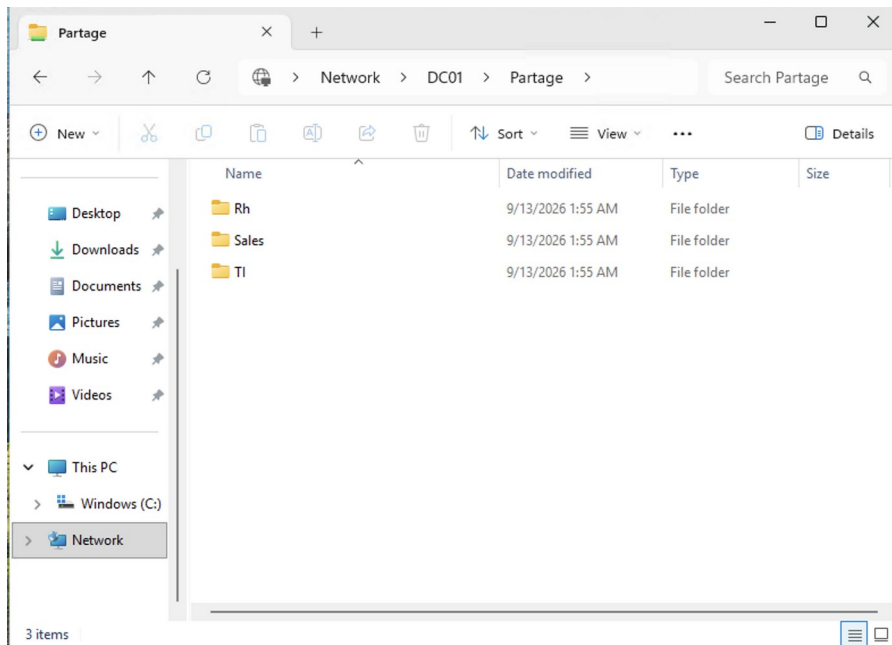


Figure 9. Accès au partage réseau depuis Client01, sur le même réseau virtuel que DC01.

Ce test a été fait avec un compte membre de Gr-RH. Le dossier Rh s'est ouvert normalement, alors que TI et Sales ont renvoyé un message d'accès refusé. C'est la preuve concrète que le principe du moindre privilège fonctionne : chaque groupe ne voit que ce qui le concerne.

C'est en fait une bonne chose que l'accès externe soit bloqué : dans une vraie entreprise, un partage de fichiers interne n'est jamais exposé directement sur Internet. Le test qui compte vraiment, c'est celui-ci, réussi depuis Client01, sur le réseau interne.